

API Design

1. Global API Standards & Conventions

1.1 Base URL

```
http://localhost:3000/api
```

All route URLs documented below are relative to this base URL.

1.2 Common Request Headers

Header	Value	Description
Content-Type	application/json	Required for all requests with a JSON body.
Authorization	Bearer <access_token>	Required for all protected routes (JWT access token).

1.3 Standard Response Envelope

All API responses return a uniform JSON envelope to guarantee predictable client-side parsing.

Success Response Envelope (2xx)

```
{
  "success": true,
  "message": "Operation description",
  "data": {}
}
```

Paginated Success Response Envelope (200 OK)

```
{
  "success": true,
  "data": [],
  "pagination": {
    "page": 1,
    "limit": 10,
    "totalItems": 45,
    "totalPages": 5,
    "hasNextPage": true,
    "hasPrevPage": false
  }
}
```

Standard Error Response Envelope (4xx / 5xx)

No raw stack traces are ever exposed to the client (satisfying CURT Level 2 requirements).

```
{
  "success": false,
  "error": "Error Type / Short Summary",
  "message": "Human-readable description of what went wrong",
  "details": [
    {
      "field": "email",
      "message": "Invalid email address format"
    }
  ]
}
```

1.4 Standard HTTP Status Codes

- **200 OK** : Successful **GET** , **PATCH** , or **DELETE** with payload.
- **201 Created** : Successful **POST** resulting in resource creation.
- **400 Bad Request** : Validation failure or invalid input payload.
- **401 Unauthorized** : Missing, expired, or cryptographically invalid JWT.
- **403 Forbidden** : Authenticated user lacks permission (RBAC / Ownership violation).
- **404 Not Found** : Target resource does not exist.
- **409 Conflict** : Unique constraint violation (e.g. email or username already taken).
- **429 Too Many Requests** : Rate limit exceeded (e.g. repeated login attempts).
- **500 Internal Server Error** : Unexpected operational or database error.

2. Authentication & Sessions (/api/auth)

2.1 Register New User

Creates a user account and companion profile. The password is encrypted using `bcrypt` (10-12 salt rounds).

- **Method:** `POST`
- **Path:** `/api/auth/register`
- **Access:** Public
- **Request Body:**

```
{
  "username": "karim_amr",
  "email": "karim@curt.racing",
  "password": "SecurePassword123!",
  "name": "Karim Amr",
  "bio": "Aerodynamics Lead Engineer"
}
```

- **Validation (Zod):**
 - `username` : String, min 3, max 50, alphanumeric and underscores only.
 - `email` : String, valid email format.
 - `password` : String, min 8 chars (includes at least 1 number and 1 uppercase letter).
 - `name` : String, min 2, max 100.
 - `bio` : String, optional, max 500 chars.
- **Success Response (201 Created):**

```
{
  "success": true,
  "message": "User registered successfully",
  "data": {
    "user": {
      "id": "e4b9e7b2-1111-4444-8888-abcdef123456",
      "username": "karim_amr",
      "email": "karim@curt.racing",
      "name": "Karim Amr",
      "bio": "Aerodynamics Lead Engineer",
      "createdAt": "2026-09-20T14:00:00.000Z"
    }
  }
}
```

```
}  
}
```

- **Errors:** 400 Bad Request (Validation error), 409 Conflict (Email or username already exists).
-

2.2 Login (Get Tokens)

Verifies credentials using `bcrypt.compare`. Returns a short-lived Access Token in JSON and sets a long-lived Refresh Token in an `HttpOnly` cookie (and response body for mobile/Postman). Rate-limited to 5 attempts per 15 minutes.

- **Method:** POST
- **Path:** `/api/auth/login`
- **Access:** Public (Rate-limited: 5 requests / 15 min)
- **Request Body:**

```
{  
  "email": "karim@curt.racing",  
  "password": "SecurePassword123!"  
}
```

- **Success Response (200 OK):**

- **Headers:** `Set-Cookie: refreshToken=...; HttpOnly; Secure; SameSite=Strict; Path=/api/auth; Max-Age=604800`

```
{  
  "success": true,  
  "message": "Login successful",  
  "data": {  
    "accessToken": "eyJhbGciOiJIUzI1NiIsInR5cCI6IkpXVCJ9...",  
    "refreshToken": "d7a8f9c0-1234-4567-89ab-cdef01234567",  
    "user": {  
      "id": "e4b9e7b2-1111-4444-8888-abcdef123456",  
      "username": "karim_amr",  
      "email": "karim@curt.racing"  
    }  
  }  
}
```

- **Errors:** 400 `Bad Request` (Invalid input), 401 `Unauthorized` (Invalid email or password), 429 `Too Many Requests` (Rate limit exceeded).
-

2.3 Refresh Access Token

Exchanges an active refresh token for a brand new short-lived access token.

- **Method:** `POST`
- **Path:** `/api/auth/refresh`
- **Access:** Public (Requires refresh token in cookie or body)
- **Request Body** (Optional if cookie is sent):

```
{
  "refreshToken": "d7a8f9c0-1234-4567-89ab-cdef01234567"
}
```

- **Success Response (200 OK):**

```
{
  "success": true,
  "message": "Token refreshed successfully",
  "data": {
    "accessToken": "eyJhbGciOiJIUzI1NiIsInR5cCI6IkpXVCJ9..."
  }
}
```

- **Errors:** 401 `Unauthorized` (Missing, invalid, or expired refresh token).
-

2.4 Logout

Deletes the active refresh token row from the database and clears the auth cookie.

- **Method:** `POST`
- **Path:** `/api/auth/logout`
- **Access:** Authenticated (`Bearer <access_token>`)
- **Request Body** (Optional if cookie is sent):

```
{
  "refreshToken": "d7a8f9c0-1234-4567-89ab-cdef01234567"
}
```

- **Success Response (200 OK):**

```
{
  "success": true,
  "message": "Logged out successfully"
}
```

2.5 Get Current User (/me)

Returns the identity and profile of the user associated with the active JWT.

- **Method:** GET
- **Path:** /api/auth/me
- **Access:** Authenticated(Bearer <access_token>)
- **Success Response (200 OK):**

```
{
  "success": true,
  "data": {
    "id": "e4b9e7b2-1111-4444-8888-abcdef123456",
    "username": "karim_amr",
    "email": "karim@curt.racing",
    "profile": {
      "id": "11112222-3333-4444-5555-666677778888",
      "name": "Karim Amr",
      "bio": "Aerodynamics Lead Engineer",
      "updatedAt": "2026-09-20T14:10:00.000Z"
    }
  }
}
```

3. User Profiles (/api/profiles)

3.1 Get Current User Profile

- **Method:** GET
- **Path:** /api/profiles/me
- **Access:** Authenticated

- **Success Response (200 OK):**

```
{
  "success": true,
  "data": {
    "id": "11112222-3333-4444-5555-666677778888",
    "userId": "e4b9e7b2-1111-4444-8888-abcdef123456",
    "name": "Karim Amr",
    "bio": "Aerodynamics Lead Engineer",
    "createdAt": "2026-09-20T14:00:00.000Z",
    "updatedAt": "2026-09-20T14:00:00.000Z"
  }
}
```

3.2 Update Current User Profile

Allows modifying display name and biography without touching account credentials.

- **Method:** PATCH
- **Path:** /api/profiles/me
- **Access:** Authenticated
- **Request Body:**

```
{
  "name": "Karim Amr (Aerodynamics)",
  "bio": "Lead Engineer for FS UK 2027 Car"
}
```

- **Success Response (200 OK):**

```
{
  "success": true,
  "message": "Profile updated successfully",
  "data": {
    "id": "11112222-3333-4444-5555-666677778888",
    "userId": "e4b9e7b2-1111-4444-8888-abcdef123456",
    "name": "Karim Amr (Aerodynamics)",
    "bio": "Lead Engineer for FS UK 2027 Car",
    "updatedAt": "2026-09-20T14:45:00.000Z"
  }
}
```

3.3 View Public Profile

Allows any authenticated teammate to view a collaborator's display profile.

- **Method:** GET
- **Path:** /api/profiles/:userId
- **Access:** Authenticated
- **Success Response (200 OK):**

```
{
  "success": true,
  "data": {
    "userId": "e4b9e7b2-1111-4444-8888-abcdef123456",
    "username": "karim_amr",
    "name": "Karim Amr (Aerodynamics)",
    "bio": "Lead Engineer for FS UK 2027 Car"
  }
}
```

- **Errors:** 404 Not Found (User/Profile does not exist).
-

4. Projects (/api/projects)

4.1 Create Project

Creates a new project. The creator is stored as `created_by` and automatically assigned the `'owner'` role in `project_members`.

- **Method:** POST
- **Path:** /api/projects
- **Access:** Authenticated
- **Request Body:**

```
{
  "name": "Monocoque Chassis Optimization",
  "description": "CFRP chassis structural analysis and layup scheduling"
}
```

- **Validation:**

- `name` : String, min 2, max 150 (Required).
- `description` : String, optional.

- **Success Response (201 Created):**

```
{
  "success": true,
  "message": "Project created successfully",
  "data": {
    "id": "a0001111-2222-3333-4444-555566667777",
    "name": "Monocoque Chassis Optimization",
    "description": "CFRP chassis structural analysis and layup schedu",
    "createdBy": "e4b9e7b2-1111-4444-8888-abcdef123456",
    "role": "owner",
    "createdAt": "2026-09-20T15:00:00.000Z",
    "updatedAt": "2026-09-20T15:00:00.000Z"
  }
}
```

4.2 List My Projects (With Filtering & Pagination)

Lists only the projects the authenticated user either owns or belongs to as a member (Ownership Enforcement). Unrelated projects are never returned.

- **Method:** `GET`
- **Path:** `/api/projects`
- **Access:** Authenticated
- **Query Parameters:**

Parameter	Type	Default	Description
<code>search</code>	String	<code>""</code>	Searches project name or description
<code>sortBy</code>	String	<code>"created_at"</code>	Field: <code>"created_at"</code> or <code>"name"</code>
<code>order</code>	String	<code>"desc"</code>	Sort direction: <code>"asc"</code> or <code>"desc"</code>
<code>page</code>	Integer	<code>1</code>	Page number
<code>limit</code>	Integer	<code>10</code>	Items per page (max 50)

- **Example URL:** `GET /api/projects?search=Chassis&sortBy=created_at&order=desc&page=1&limit=10`

- **Success Response (200 OK):**

```
{
  "success": true,
  "data": [
    {
      "id": "a0001111-2222-3333-4444-555566667777",
      "name": "Monocoque Chassis Optimization",
      "description": "CFRP chassis structural analysis and layup sche
      "myRole": "owner",
      "memberCount": 4,
      "taskCount": 8,
      "createdAt": "2026-09-20T15:00:00.000Z"
    }
  ],
  "pagination": {
    "page": 1,
    "limit": 10,
    "totalItems": 1,
    "totalPages": 1,
    "hasNextPage": false,
    "hasPrevPage": false
  }
}
```

4.3 Get Single Project Details

Returns project metadata, summary statistics, and active member list. User must be an owner or member of this project.

- **Method:** GET
- **Path:** /api/projects/:id
- **Access:** Authenticated (Owner or Member only)
- **Success Response (200 OK):**

```
{
  "success": true,
  "data": {
    "id": "a0001111-2222-3333-4444-555566667777",
    "name": "Monocoque Chassis Optimization",
    "description": "CFRP chassis structural analysis and layup schedu
    "createdBy": "e4b9e7b2-1111-4444-8888-abcdef123456",
```

```

    "myRole": "owner",
    "createdAt": "2026-09-20T15:00:00.000Z",
    "updatedAt": "2026-09-20T15:00:00.000Z",
    "members": [
      {
        "userId": "e4b9e7b2-1111-4444-8888-abcdef123456",
        "username": "karim_amr",
        "name": "Karim Amr",
        "role": "owner"
      },
      {
        "userId": "f5c0f8c3-2222-5555-9999-bcdef2345678",
        "username": "nour_tarek",
        "name": "Nour Tarek",
        "role": "member"
      }
    ]
  }
}

```

- **Errors:** `403 Forbidden` (User is neither owner nor member of this project), `404 Not Found`.
-

4.4 Update Project Details

Updates project name or description. **Owner ONLY**.

- **Method:** `PATCH`
- **Path:** `/api/projects/:id`
- **Access:** Authenticated (**Owner ONLY**)
- **Request Body:**

```

{
  "name": "Monocoque Chassis Optimization v2",
  "description": "Updated laminate schedules for front bulkhead."
}

```

- **Success Response (`200 OK`):**

```

{
  "success": true,
  "message": "Project updated successfully",
}

```

```
"data": {
  "id": "a0001111-2222-3333-4444-555566667777",
  "name": "Monocoque Chassis Optimization v2",
  "description": "Updated laminate schedules for front bulkhead.",
  "updatedAt": "2026-09-20T15:30:00.000Z"
}
```

- **Errors:** `403 Forbidden` ("Forbidden: Only project owners can edit project details").
-

4.5 Delete Project

Permanently deletes the project. Automatically cascades deletion of associated `project_members` and `tasks`. **Owner ONLY**.

- **Method:** `DELETE`
- **Path:** `/api/projects/:id`
- **Access:** Authenticated (**Owner ONLY**)
- **Success Response (`200 OK`):**

```
{
  "success": true,
  "message": "Project and all associated tasks deleted successfully"
}
```

- **Errors:** `403 Forbidden` ("Forbidden: Only project owners can delete the project").
-

5. Project Membership

(`/api/projects/:id/members`)

5.1 List Project Members

- **Method:** `GET`
- **Path:** `/api/projects/:id/members`
- **Access:** Authenticated (Owner or Member)
- **Success Response (`200 OK`):**

```
{
  "success": true,
  "data": [
    {
      "id": "junction-uuid-1",
      "userId": "e4b9e7b2-1111-4444-8888-abcdef123456",
      "username": "karim_amr",
      "name": "Karim Amr",
      "role": "owner",
      "joinedAt": "2026-09-20T15:00:00.000Z"
    },
    {
      "id": "junction-uuid-2",
      "userId": "f5c0f8c3-2222-5555-9999-bcdef2345678",
      "username": "nour_tarek",
      "name": "Nour Tarek",
      "role": "member",
      "joinedAt": "2026-09-20T15:15:00.000Z"
    }
  ]
}
```

5.2 Add Member to Project

Adds an existing user to the project as a **'member'** . **Owner ONLY**.

- **Method:** **POST**
- **Path:** **/api/projects/:id/members**
- **Access:** Authenticated (**Owner ONLY**)
- **Request Body:**

```
{
  "userId": "f5c0f8c3-2222-5555-9999-bcdef2345678"
}
```

- **Success Response (201 Created):**

```
{
  "success": true,
  "message": "Member added to project successfully",
  "data": {
```

```
    "projectId": "a0001111-2222-3333-4444-555566667777",
    "userId": "f5c0f8c3-2222-5555-9999-bcdef2345678",
    "role": "member",
    "joinedAt": "2026-09-20T15:15:00.000Z"
  }
}
```

- **Errors:** 400 *Bad Request* (User does not exist), 403 *Forbidden* (Only owner can add members), 409 *Conflict* (User is already a member).
-

5.3 Remove Member from Project

Removes a user from the project. **Owner ONLY**. Cannot remove the project owner.

- **Method:** DELETE
- **Path:** /api/projects/:id/members/:userId
- **Access:** Authenticated (**Owner ONLY**)
- **Success Response (200 OK):**

```
{
  "success": true,
  "message": "Member removed from project successfully"
}
```

- **Errors:** 400 *Bad Request* (Cannot remove the project owner), 403 *Forbidden* (Only owner can remove members).
-

6. Tasks (/api/tasks & /api/projects/:id/tasks)

6.1 Create Task

Creates a new task within a project. **Owner ONLY**.

[!IMPORTANT]

CURT Data Integrity Rule: If *assignedTo* is provided, the backend **must verify** that the user exists and is an active member of this project.

- **Method:** POST

- **Path:** `/api/projects/:id/tasks`
- **Access:** Authenticated (**Owner ONLY**)
- **Request Body:**

```
{
  "title": "Perform FEA on Front Bulkhead",
  "description": "Run 20g impact simulation in ANSYS and report torsion",
  "priority": "High",
  "status": "To Do",
  "assignedTo": "f5c0f8c3-2222-5555-9999-bcdef2345678"
}
```

- **Validation:**
 - `title` : String, min 1, max 200 (Required).
 - `description` : String, optional.
 - `priority` : Enum: 'Low' , 'Medium' , 'High' (Default: 'Medium').
 - `status` : Enum: 'To Do' , 'In progress' , 'Done' (Default: 'To Do').
 - `assignedTo` : UUID, optional. Must belong to `project_members` for this project.
- **Success Response (201 Created):**

```
{
  "success": true,
  "message": "Task created successfully",
  "data": {
    "id": "t1112222-3333-4444-5555-666677778888",
    "projectId": "a0001111-2222-3333-4444-555566667777",
    "title": "Perform FEA on Front Bulkhead",
    "description": "Run 20g impact simulation in ANSYS and report torsion",
    "priority": "High",
    "status": "To Do",
    "assignedTo": "f5c0f8c3-2222-5555-9999-bcdef2345678",
    "createdAt": "2026-09-20T16:00:00.000Z",
    "updatedAt": "2026-09-20T16:00:00.000Z"
  }
}
```

- **Errors:** `400 Bad Request` (Assignee is not a member of this project), `403 Forbidden` (Only owner can create tasks).

6.2 List Tasks (Advanced Filtering, Searching, Sorting & Pagination)

Lists tasks inside a project. Accessible by project Owner and Members. Supports all Level 2 and Level 3 query criteria.

- **Method:** GET
- **Path:** /api/projects/:id/tasks
- **Access:** Authenticated (Owner or Member)
- **Query Parameters:**

Parameter	Type	Default	Example	Description
status	String	undefined	Done	Filters by task status (To Do , In progress , Done)
priority	String	undefined	High	Filters by priority (Low , Medium , High)
assignedTo	UUID	undefined	<uuid>	Filters by assigned user ID
search	String	""	FEA	Substring search on title and description
sortBy	String	"created_at"	"priority"	Sort field: "created_at" , "priority" , "status"
order	String	"desc"	"asc"	Sort direction: "asc" or "desc"
page	Integer	1	1	Page number
limit	Integer	10	10	Page limit (max 50)

- **Example URL:** GET /api/projects/:id/tasks?status=In%20progress&priority=High&sortBy=created_at&order=desc&page=1&limit=10
- **Success Response (200 OK):**

```
{
  "success": true,
  "data": [
    {
      "id": "t1112222-3333-4444-5555-666677778888",
      "projectId": "a0001111-2222-3333-4444-555566667777",
      "title": "Perform FEA on Front Bulkhead",
```

```

        "description": "Run 20g impact simulation in ANSYS and report t
        "priority": "High",
        "status": "In progress",
        "assignedTo": {
            "id": "f5c0f8c3-2222-5555-9999-bcdef2345678",
            "username": "nour_tarek",
            "name": "Nour Tarek"
        },
        "createdAt": "2026-09-20T16:00:00.000Z",
        "updatedAt": "2026-09-20T16:15:00.000Z"
    }
],
"pagination": {
    "page": 1,
    "limit": 10,
    "totalItems": 1,
    "totalPages": 1,
    "hasNextPage": false,
    "hasPrevPage": false
}
}

```

6.3 Get Single Task Details

- **Method:** `GET`
- **Path:** `/api/tasks/:id`
- **Access:** Authenticated (User must belong to the task's parent project)
- **Success Response (200 OK):**

```

{
    "success": true,
    "data": {
        "id": "t1112222-3333-4444-5555-666677778888",
        "projectId": "a0001111-2222-3333-4444-555566667777",
        "title": "Perform FEA on Front Bulkhead",
        "description": "Run 20g impact simulation in ANSYS and report to
        "priority": "High",
        "status": "In progress",
        "assignedTo": "f5c0f8c3-2222-5555-9999-bcdef2345678",
        "createdAt": "2026-09-20T16:00:00.000Z",
        "updatedAt": "2026-09-20T16:15:00.000Z"
    }
}

```

```
}  
}
```

- **Errors:** `403 Forbidden` (User does not belong to the project this task is in), `404 Not Found`.
-

6.4 Update Task Details (Full Edit)

Edits task title, description, priority, or reassigns `assignedTo`. **Owner ONLY**.

[!NOTE]

If a Member attempts this endpoint, the backend rejects with `403 Forbidden`. Members must use `PATCH /api/tasks/:id/status`.

- **Method:** `PATCH`
- **Path:** `/api/tasks/:id`
- **Access:** Authenticated (**Owner ONLY**)
- **Request Body:**

```
{  
  "title": "Perform FEA on Front & Rear Bulkheads",  
  "priority": "Medium",  
  "assignedTo": "e4b9e7b2-1111-4444-8888-abcdef123456"  
}
```

- **Success Response (`200 OK`):**

```
{  
  "success": true,  
  "message": "Task updated successfully",  
  "data": {  
    "id": "t1112222-3333-4444-5555-666677778888",  
    "title": "Perform FEA on Front & Rear Bulkheads",  
    "priority": "Medium",  
    "assignedTo": "e4b9e7b2-1111-4444-8888-abcdef123456",  
    "updatedAt": "2026-09-20T16:30:00.000Z"  
  }  
}
```

- **Errors:** `400 Bad Request` (Reassigned user is not a project member), `403 Forbidden` (Only owner can edit task specifications).
-

6.5 Update Task Status ONLY (Level 3 RBAC)

Allows updating the task status('To Do' , 'In progress' , 'Done').

- **Allowed For:**

1. The project **Owner**.
2. The **Member** who is assigned to this specific task(`task.assigned_to == current_user.id`).

- **Forbidden For:**

- Any Member trying to update a task assigned to someone else (`403 Forbidden`).

- **Method:** `PATCH`

- **Path:** `/api/tasks/:id/status`

- **Access:** Authenticated (Owner OR Assigned Member)

- **Request Body:**

```
{
  "status": "Done"
}
```

- **Validation:**

- `status` : Enum: 'To Do' , 'In progress' , 'Done' (Required).

- **Success Response (`200 OK`):**

```
{
  "success": true,
  "message": "Task status updated successfully",
  "data": {
    "id": "t1112222-3333-4444-5555-666677778888",
    "status": "Done",
    "updatedAt": "2026-09-20T16:45:00.000Z"
  }
}
```

- **Errors:** `403 Forbidden` ("Forbidden: You can only update the status of tasks assigned to you").

6.6 Delete Task

Permanently deletes a task. **Owner ONLY**.

- **Method:** `DELETE`
- **Path:** `/api/tasks/:id`
- **Access:** Authenticated (**Owner ONLY**)
- **Success Response (`200 OK`):**

```
{
  "success": true,
  "message": "Task deleted successfully"
}
```

- **Errors:** `403 Forbidden` ("Forbidden: Only project owners can delete tasks").
-

7. Security & Rate Limiting Specifications

- **Brute-Force Rate Limiter:**
 - Target: `POST /api/auth/login`
 - Window: 15 minutes
 - Max Attempts: 5 per IP address
 - Response on Breach: `429 Too Many Requests`
- **Input Sanitization:**
 - Parameterized SQL queries via Drizzle ORM prevent SQL injection.
 - Zod schemas sanitize strings and strip extraneous body parameters (`zod.strict()`).
- **Security Headers:**
 - Helmet middleware applied globally (`Content-Security-Policy` , `X-Content-Type-Options` , `X-Frame-Options`).